

ISO/IEC 27001 Lead Implementer

Course Objectives

After completing this course, you will be able to:

1. Understand the concept of information security
2. Recognize the importance of information security in organizational and societal contexts
3. Understand and apply core principles of information security (e.g., confidentiality, integrity, availability)
4. Define the purpose and structure of management system standards
5. Understand and explain the components of an Information Security Management System (ISMS)
6. Identify the structure and scope of the ISO/IEC 27000 family of standards
7. Recognize key information security standards and best practices
8. Understand the legal and regulatory landscape for information security in the United States and Europe
9. Identify the key requirements of ISO/IEC 27001.
10. Develop an implementation plan for the ISMS
11. Understand the stages and structure of an ISMS implementation project
12. Establish documented information in accordance with ISO/IEC 27001
13. Outline the business case for ISO/IEC 27001
14. Understand the definition and key components of a project charter
15. Recognize the importance of securing and sustaining management support
16. Recognize the importance of leadership commitment to information security
17. Assign roles and responsibilities for ISMS implementation and governance
18. Establish the internal and external context of the organization
19. Conduct stakeholder analysis to identify and assess interested parties
20. Define the scope of the Information Security Management System (ISMS)
21. Recognize the benefits of performing a gap analysis
22. Conduct a gap analysis to identify information security compliance gaps
23. Select tools and techniques for conducting an effective gap analysis
24. Understand the purpose and structure of an information security policy
25. Establish information security objectives
26. Develop and implement a communication plan
27. Ensure personnel are competent based on education, training, or experience
28. Develop and deliver training and awareness programs
29. Evaluate and document competence of ISMS personnel
30. Maintain an inventory of information assets
31. Assign ownership of information assets
32. Develop and apply an information classification scheme
33. Understand key risk concepts, including threats and vulnerabilities
34. Describe the relationship between risks, controls, and residual risk
35. Define risk assessment and acceptance criteria

36. Establish a risk assessment process
37. Establish a risk treatment process
38. Conduct information security risk assessments
39. Identify and allocate necessary resources
40. Develop and implement risk treatment plans
41. Understand the purpose, objectives, attributes, and types of security controls
42. Navigate the reference controls in Annex A
43. Manage operations of the Information Security Management System (ISMS)
44. Establish a monitoring and measurement process for the ISMS
45. Conduct monitoring and review activities to evaluate ISMS effectiveness and information security performance
46. Define key performance indicators (KPIs) and collect relevant monitoring data
47. Conduct internal audits and understand the steps of the audit process
48. Perform management reviews with top management
49. Identify opportunities for continual improvement
50. Define and implement corrective actions
51. Verify the effectiveness of corrective actions
52. Plan and evaluate changes made to the ISMS
53. Discuss the ISO/IEC 27001 certification process
54. Implement security controls in accordance with ISO/IEC 27002